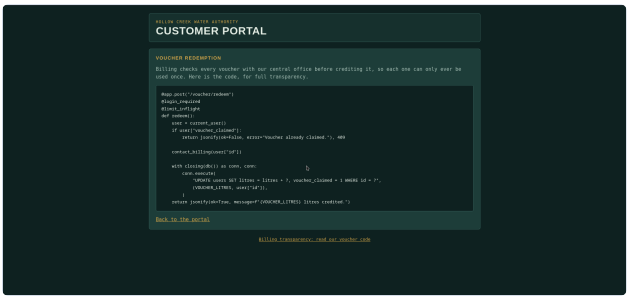
Water Hammer

Web Exploitation



I began by registering an account on http://web.secleaf.xyz:8880/, which gave a starting municipal balance of 100 litres. The Reserve Valve endpoint required at least 1,000 litres to open.

The application featured a one-time promo voucher worth 50L. Attempting multiple redemptions normally returned a 'Voucher already claimed' error due to a database state check.

I identified a Time-of-Check to Time-of-Use (TOCTOU) race condition in the voucher redemption handler. Using concurrent worker threads synchronized with a thread barrier, I fired 96 parallel redemption requests within the same millisecond.

Finally, I tested the recovered flag against the executable / service:

python3 Water_Hammer.py

Account balance reached: 1150L (Threshold: 1000L)

Flag Captured

SecLeaf{ch3ck_f1r5t_wr1t3_l4t3r_b00m}

BY:JOKER_53